

This is the right strategic question.

If you're building a **serious AI security platform**, you should think in terms of **security layers** (defense in depth).

Below is a **complete structured map** from inner code to outer infrastructure.

The Complete Security Layer Model

Think of it like concentric circles:

Code → Dependencies → Container → Runtime → API → Network → Cloud → CI/CD → Monitoring

Now let's break each one clearly.

Code Security (Application Layer)

Focus: How the app is written.

Covers:

- SQL / NoSQL Injection
- XSS
- CSRF
- SSRF
- Broken authentication
- Broken access control
- Business logic flaws
- Hardcoded secrets
- Insecure deserialization
- Memory bugs (C/C++)

Tools:

- Semgrep
 - SonarQube
-

2 Dependency Security (SCA)

Focus: Third-party libraries.

Covers:

- CVEs in npm/pip/maven packages
- Malicious packages
- License risks
- Transitive dependency risks

Tools:

- Snyk
 - OWASP Dependency-Check
-

3 Container Security

Focus: Docker & Kubernetes layer.

Covers:

- Vulnerable base images
- Root containers
- Privileged pods
- Exposed internal services
- Image tampering

Tools:

- Trivy
 - Aqua Security
-

4 Runtime Security

Focus: What happens when app is running.

Covers:

- Unexpected process execution
- Reverse shells
- Suspicious syscalls

- Container breakout attempts

Tools:

- Falco
-

5 **API Security**

Focus: API exposure & misuse.

Covers:

- No rate limiting
 - Broken object-level authorization
 - Mass assignment
 - Excessive data exposure
 - GraphQL introspection abuse
-

6 **Network Security**

Focus: Infrastructure exposure.

Covers:

- Open ports
- Weak TLS
- Exposed databases
- Firewall misconfig
- DNS misconfig

Tools:

- Nmap
 - Nuclei
-

7 **Cloud Security**

Focus: Cloud platform misconfigurations.

Covers:

- Public S3 buckets
- Over-permissive IAM roles
- Open security groups
- Exposed metadata service
- Unencrypted storage

Platforms:

- Amazon Web Services
 - Microsoft Azure
 - Google Cloud
-

CI/CD Pipeline Security

Focus: Build & deployment chain.

Covers:

- Insecure GitHub Actions
- Secrets exposed in logs
- Dependency poisoning
- Malicious PR injection
- Artifact tampering

Platform:

- GitHub
-

Identity & Access Management (IAM)

Focus: Who can access what.

Covers:

- Privilege escalation
- Role misconfiguration
- Weak MFA
- Over-permissioned tokens

10

Monitoring & Logging Security

Focus: Detection & response.

Covers:

- Missing audit logs
 - No alerting
 - No intrusion detection
 - No anomaly detection
-

11

Data Security Layer

Focus: Protecting sensitive data.

Covers:

- Encryption at rest
 - Encryption in transit
 - Tokenization
 - Data masking
 - PII exposure
-

12

Endpoint Security (Advanced)

Focus: Machines running your services.

Covers:

- Malware
 - Ransomware
 - EDR monitoring
-



Complete Layer Map

Layer	What It Protects
Code	Application logic
Dependencies	Third-party libraries
Container	Execution environment
Runtime	Active behavior
API	Data interfaces
Network	Exposure surface
Cloud	Infrastructure config
CI/CD	Build integrity
IAM	Access control
Monitoring	Threat detection
Data	Sensitive information
Endpoint	Host systems



If You Want Enterprise-Level AI Platform

You can structure modules like:

- Module 1 → SAST
- Module 2 → SCA
- Module 3 → Docker Scanner
- Module 4 → Kubernetes Scanner
- Module 5 → API Scanner
- Module 6 → Network Scanner
- Module 7 → Cloud Config Scanner
- Module 8 → IAM Analyzer
- Module 9 → Risk Scoring Engine
- Module 10 → AI Explanation + Fix Generator

Now you're building a **full DevSecOps intelligence platform**, not just a scanner.



Real-World Insight

Most startups only cover:

- ✓ Code
- ✓ Dependencies

Enterprise security covers:

- ✓ Everything above

If you want next, I can explain:

- 🔥 Which layers are highest priority in 2026
- 🔥 How attackers chain layers together
- 🔥 How to design unified risk scoring
- 🔥 How to phase development of your system
- 🔥 What to build first as MVP

Since you're building something serious — do you want strategy or technical deep dive next?